PENETRATION TESTING REPORT

FOOTPRINTING AND NETWORK SCANNING PHASES

WEEK 2 | CYBERSECURITY | NETWORKWALKS

Pentester Name	Shahzeb Ali
Program and Batch	NetworkWalks Cybersecurity Internship Batch B084
Date	10 November 2026
Activities covered	W2 PM1 Footprinting and Reconnaissance Nmap and Zenmap service scanning
Target	networkwalks.com Observed public address 192.232.216.135
Authorization scope	Assigned internship training target Written permission is not reproduced in this report
Phases covered	**Phase 1 Reconnaissance and footprinting** **Phase 2 Service scanning and host review** **Exploitation and post exploitation are not covered**

1 Liability Disclaimer

This report documents an educational security assessment of the designated NetworkWalks internship target. Its commands and observations must be used only within the applicable authorization and agreed scope. Public reachability does not grant permission to test a system. No exploitation, password attacks, data extraction or service disruption is claimed in this report.

The findings describe conditions observed at scan time. Configuration, access paths and software may change. Potential consequences are distinguished from confirmed behavior; the report does not certify the security of the target.

2 Introduction

I assessed the external footprint of networkwalks.com using six Kali Linux tools and reviewed an active Nmap scan in Zenmap. The combined results identify domain and DNS infrastructure, web technologies, HTTP behavior, a detected web application firewall and reachable TCP services. The primary review priorities are the database listener and enforcement of encryption and access controls on file transfer, mail and remote administration services.

The recorded Nmap command scanned one domain target and reported one host up. The Ports and Hosts view contains 14 open TCP ports and three filtered TCP ports. It is not a local subnet discovery exercise, and no local IP inventory or MAC address list is claimed. OS detection was inconclusive. All ten figures in Section 8 correspond to my evidence, rather than the example screenshots in the report template.

2 1 Scope and Evidence Limits

Target: networkwalks.com, observed at 192.232.216.135. The activities comprise registry lookups, DNS queries, web fingerprinting, HTTP header inspection, WAF detection, and an active Nmap scan with default scripts. Full XML output and complete script results are not available in the evidence set. A banner, open port or missing header does not establish an exploitable vulnerability. No new scan was run to prepare this report.

3 Tools Used

Tool	Purpose
Kali Linux	Environment for the documented reconnaissance commands.
WHOIS	Domain registrar, lifecycle, EPP locks, nameservers and DNSSEC status.
WhatWeb	HTTP behavior, web server, CMS, plugin and frontend fingerprints.
NSLookup	Resolve the target domain using the local recursive resolver.
cURL with -I	Inspect an HTTPS HEAD response and cookie attributes.
WAFW00F 2.4.2	Identify a web application firewall from HTTP responses.
DNSRecon	Enumerate SOA, NS, MX, A and SRV data and DNS banners.
Nmap and Zenmap	Active service discovery, version detection, OS guesses and topology review.

4 Activities Performed

4 1 Footprinting and Reconnaissance

4 1 WHOIS

Command: whois networkwalks.com

Impact level: Low for unsigned DNSSEC and Informational for registry data.

Observation: GoDaddy.com LLC is the registrar, with IANA ID 146. The domain was created on 6 November 2019, updated on 12 November 2025 and expires on 6 November 2027. The authoritative nameservers are NS6135.HOSTGATOR.COM and NS6136.HOSTGATOR.COM. The output lists clientDeleteProhibited, clientRenewProhibited, clientTransferProhibited and clientUpdateProhibited, and reports DNSSEC as unsigned.

Interpretation: The registry data supports domain and hosting attribution. EPP locks are observed controls, but do not guarantee protection against all registrar account attacks. Unsigned DNSSEC removes DNSSEC authentication for the zone; it does not demonstrate a successful spoofing or poisoning attack. Evidence E01 in Section 8.

4 1 WhatWeb

Command: whatweb networkwalks.com

Impact level: Low for version disclosure and Informational for normal web behavior.

Observation: HTTP redirects to HTTPS with 301 Moved Permanently; HTTPS returns 200 OK. The output reports Apache, WordPress 7.1.4, WordPress Download Manager 3.3.76, jQuery 3.7.1 and Bootstrap 7.1.4. It also identifies the page title Networkwalks Academy, public address 192.232.216.135 and contact email info@networkwalks.com.

Interpretation: These are tool-reported fingerprints, not independently verified package versions. The Bootstrap and CMS values should be validated against the application inventory before mapping vulnerabilities. Exposed versions can assist reconnaissance, but no affected CVE is established. Evidence E02 in Section 8.

4 1 NSLookup

Command: nslookup networkwalks.com

Impact level: Informational.

Observation: The domain resolves to 192.232.216.135 in the earlier recorded analysis, consistent with WhatWeb and DNSRecon. The displayed NSLookup screenshot masks the local resolver and part of the returned address.

Interpretation: A non-authoritative response means the answer came from the recursive resolver rather than directly from an authoritative server. Public DNS mapping is expected and does not prove an origin bypass or a vulnerability. Redacted address characters are corroborated by the other figures, not inferred from the blur. Evidence E03 in Section 8.

4 1 cURL

Command: curl -I https://networkwalks.com

Impact level: Low for hardening observations and Informational for API discovery.

Observation: The captured response is HTTP/2 200 with server Apache, x-endurance-cache-level 0 and x-nginx-cache WordPress. The Link header advertises /wp-json/ and /wp-json/wp/v2/pages/53. The __wpdm_client cookie includes Secure and HttpOnly; its value is redacted and no SameSite attribute is

visible. HSTS, CSP, X-Frame-Options and X-Content-Type-Options are absent from this captured response.

Interpretation: The cache header suggests a hosting cache layer but does not prove a complete proxy architecture. Missing headers and an explicit SameSite policy require configuration review; CSRF, clickjacking and transport downgrade were not validated. A public REST API link is not evidence of unauthorized API access. Evidence E04 in Section 8.

4 1 WAFW00F

Command: wafw00f networkwalks.com

Impact level: Informational observed control.

Observation: WAFW00F 2.4.2 reports that https://networkwalks.com is behind ModSecurity SpiderLabs, identified in two requests.

Interpretation: This is an observed defensive technology. The result does not establish the installed rule set, coverage, effectiveness, rate limiting or an exploitable bypass. A WAF supplements application security and access controls. Evidence E05 in Section 8.

4 1 DNSRecon

Command: dnsrecon -d networkwalks.com

Impact level: Low for version disclosure and unsigned DNSSEC indicators.

Observation: SOA is ns6135.hostgator.com at 50.87.144.87. NS records identify ns6135.hostgator.com and ns6136.hostgator.com at 192.232.216.131, both reporting BIND 9.16.23-RH. The MX mail.networkwalks.com and the domain A record resolve to 192.232.216.135. The autodiscover SRV service points to cpanelemaildiscovery.cpanel.net on port 443 across eight returned endpoint addresses. DNSRecon displays eight SRV results and no answer for its DNSSEC query.

Interpretation: The DNSSEC query failure alone would not establish an unsigned zone; the separate WHOIS output reports unsigned status. Shared web and mail addressing does not prove physical colocation or weak tenant isolation. cPanel autodiscovery indicates a service convention, not confirmed exposed cPanel administration. No SPF, DKIM, DMARC, open recursion or zone-transfer result is shown. Evidence E06 in Section 8.

4 2 Network Scanning with Zenmap

Recorded command: nmap -T4 -A -v networkwalks.com

The -T4 option selects faster timing; -A enables OS detection, service and version detection, default script scanning and traceroute; -v increases output detail. This is active scanning. No -p- or UDP scan option is shown, so the evidence does not establish coverage of all TCP ports or UDP services. The results are summarized below and illustrated by E07 to E10.

TCP port	State	Service	Reported banner	Impact level
21	Open	FTP	Pure-FTPd with SSL/TLS	Medium provisional
22	Open	SSH	OpenSSH 9.9 protocol 2.0	Low
25	Filtered	SMTP label	No banner	Informational
26	Open	SMTP	Exim smtpd 4.100.1	Medium provisional

TCP port	State	Service	Reported banner	Impact level
53	Open	DNS	ISC BIND 9.16.23 Red Hat Linux	Low
80	Open	HTTP	Apache httpd	Informational
110	Open	POP3	Dovecot pop3d	Medium provisional
143	Open	IMAP	Dovecot imapd	Medium provisional
443	Open	HTTP label	Apache httpd	Informational
465	Open	SMTP	Exim smtpd 4.100.1	Informational
587	Open	SMTP	Exim smtpd 4.100.1	Informational
993	Open	IMAP	Dovecot imapd	Informational
995	Open	POP3	Dovecot pop3d	Informational
1720	Filtered	h323q931 label	No banner	Informational
2222	Open	SSH	OpenSSH 9.9 protocol 2.0	Low
3306	Open	MySQL	MySQL 5.7.44-48	Medium provisional
5060	Filtered	SIP label	No banner	Informational

Open means a listener accepted the scan probes from this vantage point. Filtered means the scanner could not determine open versus closed; it is not proof of an active SMTP, SIP or H.323 service. The conventional encrypted mail ports 465, 993 and 995 are not proof of correct TLS settings. Likewise, port 443 alone does not validate a certificate or cipher configuration.

4 3 Host Identification and Topology

The scan reports one host up and completion in 96.25 seconds, with 1,083 raw packets sent and 1,042 received. Service information identifies gator3068.hostgator.com and Linux. Separately, TCP/IP fingerprinting reports no exact OS match and non-ideal test conditions. Its competing guesses are AT&T BGW210 at 88 percent, Oracle VirtualBox Slirp NAT bridge at 87 percent and QEMU user-mode network gateway at 87 percent. None is a verified target device identity.

The Host Viewer repeats the imperfect matches and lists 21/tcp open as a used fingerprinting port. The output reports a one-hop distance with traceroute using port 80. The topology figure shows localhost and a connected node with other details redacted. NAT or middlebox effects are possible explanations for the unusual fingerprints, not confirmed causes. The graph does not establish physical location, LAN membership or a complete route. A red node is not a validated vulnerability rating.

5 Risk Analysis and Impact

Impact labels are qualitative analyst assessments, not CVSS scores. Informational covers expected inventory, uncertain results and observed controls. Low covers limited disclosure or hardening gaps. Medium provisional identifies an exposed service whose security policy needs validation. No High or Critical vulnerability is established by the evidence.

ID	Impact level	Finding	Evidence	Potential impact
F01	Medium provisional	Reachable database	E07: 3306 open; MySQL banner.	A separate access weakness could expose or alter database data; access was not demonstrated.
F02	Medium provisional	File transfer encryption policy	E07: 21 open; SSL/TLS advertised.	Optional encryption could expose credentials or files to on-path observers; enforcement was not tested.
F03	Medium provisional	Mail encryption and relay policy	E07: 26, 110 and 143 open.	Weak authentication or TLS could enable credential exposure or mail abuse; neither was confirmed.
F04	Low	Remote administration on two ports	E07: 22 and 2222 open.	Additional administration exposure; no weak credentials or insecure configuration demonstrated.
F05	Low	Application and DNS version disclosure	E02, E06, E07: software versions.	Assists focused research; vulnerable packages or applicable CVEs are not established.
F06	Low	DNSSEC reported unsigned	E01 unsigned; E06 query unanswered.	Removes DNSSEC authenticity protection; poisoning feasibility was not demonstrated.
F07	Low	HTTP hardening headers	E04: four hardening headers absent.	Reduced defense in depth; framing, content handling or downgrade impact requires validation.
F08	Low	No explicit SameSite cookie attribute	E04: no explicit SameSite.	Cross-site behavior depends on browser and application; no CSRF demonstrated.
F09	Informational	Public DNS and REST discovery	E01 to E06: DNS and API links.	Expected public discovery data; no unauthorized API access or origin bypass demonstrated.
F10	Informational control	ModSecurity detection	E05: ModSecurity in two requests.	Defensive technology identified; coverage and effectiveness remain untested.
F11	Informational	OS and route uncertainty	E08 to E10: imperfect OS and route data.	May cause incorrect asset attribution; no target OS or LAN inventory confirmed.

Assessment limits: Medium findings are review priorities rather than proven compromise paths. No vulnerability exploitation, password attack, unrestricted recursion, zone transfer, open relay, successful database login or insecure TLS configuration is established by these screenshots. Port and banner results should be validated by the system owner before severity is escalated.

6 Recommendations

1 Restrict database access

F01: Allow MySQL connections only from approved application and administration sources. Review bind addresses, firewall rules, least-privilege accounts, required TLS and the exact vendor package support status. Confirm the restriction from an authorized external vantage.

2 Enforce encrypted file transfer

F02: Require TLS before FTP authentication and protect data transfers, or use an approved SFTP workflow. Disable anonymous access unless needed and explicitly controlled. Validate enforcement rather than assuming that the SSL/TLS banner is sufficient.

3 Review mail authentication and transport

F03: Require STARTTLS before authentication on applicable mail listeners; review the alternate SMTP service on port 26. Validate relay restrictions, submission authentication, certificates and mail authentication records with the owner. Remove unused listeners.

4 Limit remote administration

F04: Confirm that both SSH endpoints are needed. Restrict source access, use keys and suitable MFA where supported, limit permitted users and review privileged login. A nonstandard port is not an access-control measure.

5 Verify software versions and patching

F05: Compare banners with the installed CMS, plugins, SSH, DNS, mail and database package inventory. Account for vendor security backports. Maintain supported releases and remove unnecessary banner detail without treating banner suppression as a substitute for patching.

6 Review DNSSEC and DNS service policy

F06: Coordinate DNSSEC signing and DS publication with the provider and registrar. Validate authoritative TCP DNS requirements, recursion restrictions and zone-transfer policy. Do not remove required public DNS records merely because they are discoverable.

7 Harden web responses and cookie behavior

F07 and F08: Assess HSTS readiness, appropriate CSP and framing controls, X-Content-Type-Options and an explicit SameSite policy. Test representative responses and application flows before rollout. Retain Secure, HttpOnly and application anti-CSRF controls.

8 Review intended public interfaces

F09 and F10: Verify REST endpoint permissions and intentionally public fields. Maintain the ModSecurity deployment and monitor its logs, while retaining application validation and access controls. WAF identification does not establish protection against every attack.

9 Improve evidence and asset records

F11: Keep complete authorized Nmap XML, command profiles, timestamps and scope records. Resolve OS identity through owner inventory. Preserve redactions for tokens and internal details, and record configuration changes and retest results.

7 Conclusion

The Week 2 work connected domain registration, DNS information, application fingerprints and active service observations into a single external asset profile. The scan view shows 14 open TCP ports and three filtered ports for one target host. The main practical priorities are database access restrictions and verification of encryption and authentication policy for file-transfer, mail and administration services.

The assessment also demonstrated the importance of evidence quality. A version banner does not confirm an exploitable CVE; a filtered port does not prove a listening service; and imperfect OS guesses do not establish the target platform. I documented these distinctions, linked each observation to its evidence and kept conditional impacts separate from observed behavior.

Author and Project Information

Prepared by Shahzeb Ali | NetworkWalks Cybersecurity Internship | Batch B084 | Week 2

Project repository: https://github.com/ishahzebali/NETWORKWALKS-SHAHZEB-ALI-B084-WK2-PM1-FOOTPRINTING-RECONNAISSANCE-ATTACKS

Technical references

Nmap Port Scanning Basics: https://nmap.org/book/man-port-scanning-basics.html

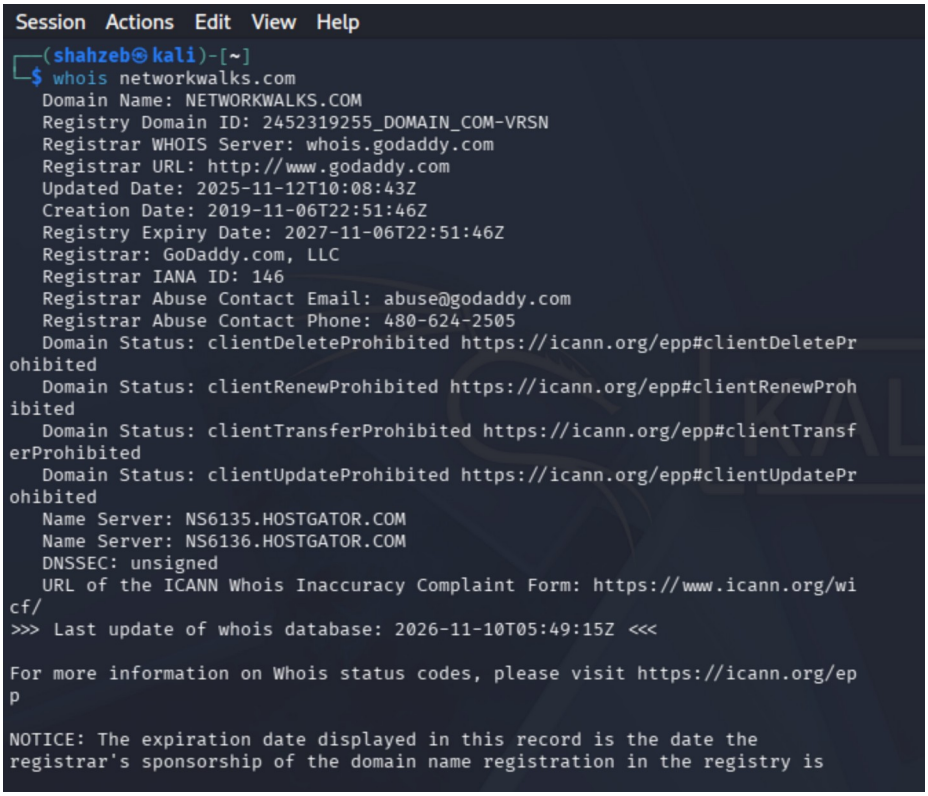
Nmap OS Detection: https://nmap.org/book/man-os-detection.html

Nmap Aggressive Scan Options: https://nmap.org/book/man-misc-options.html

8 Evidence Collected

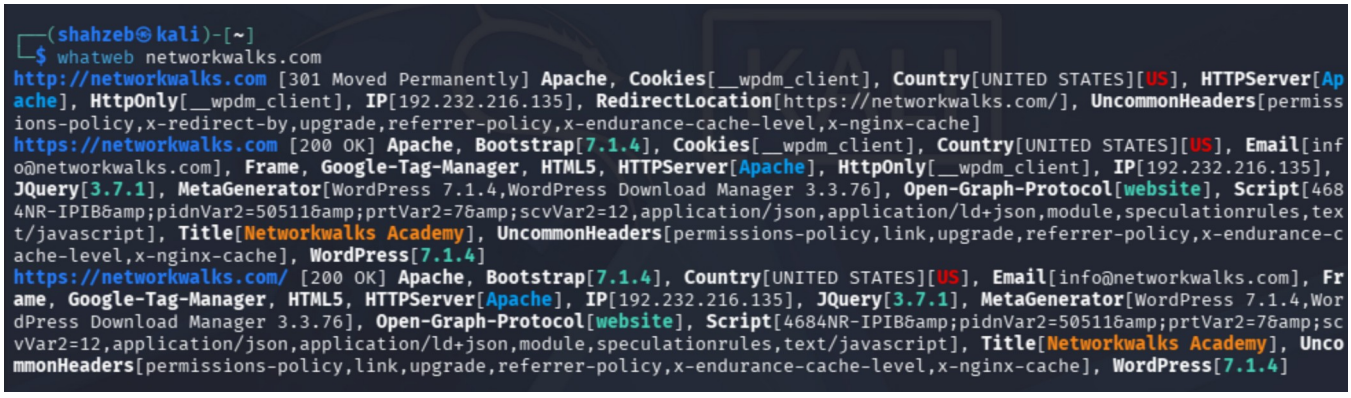
Figures E01 to E10 preserve the supplied screenshots. Cookie and internal network details remain redacted where already masked. Each figure is linked to the activity and finding it supports. The image content has not been altered for this report.

E01 WHOIS domain registration



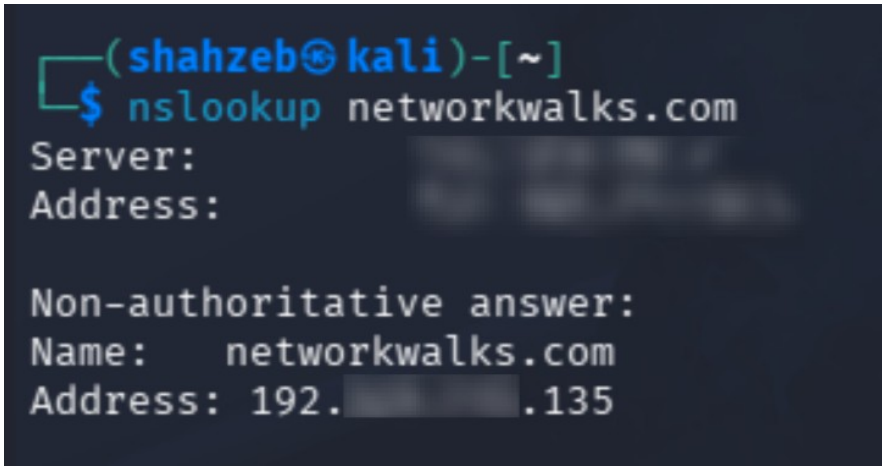
WHOIS registrar, lifecycle, nameservers, EPP locks and unsigned DNSSEC status. Supports F06 and registry inventory.

E02 WhatWeb technology fingerprints



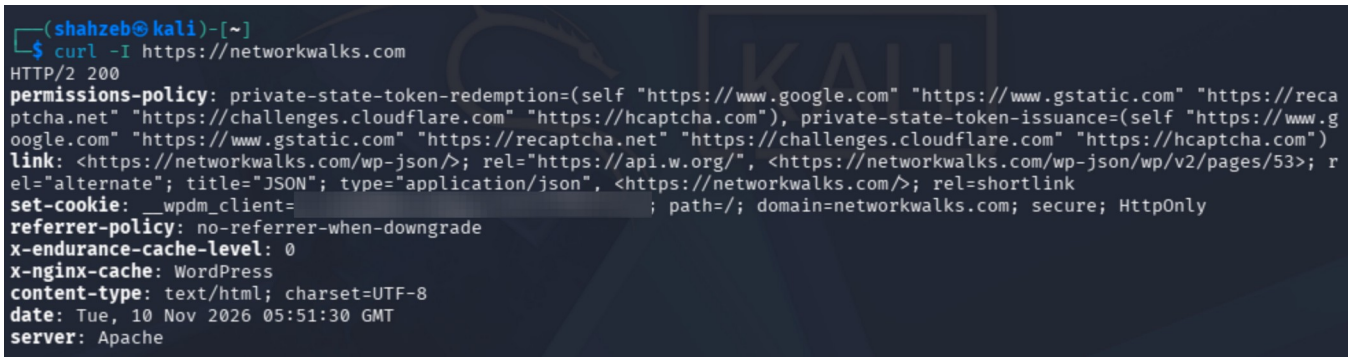
HTTP redirect and web technology fingerprints, including reported CMS and plugin versions. Supports F05 and F09.

E03 NSLookup DNS resolution



Non-authoritative domain resolution. Resolver details and part of the address are masked; the full target address is corroborated by E02 and E06. Supports F09.

E04 cURL HTTPS response headers



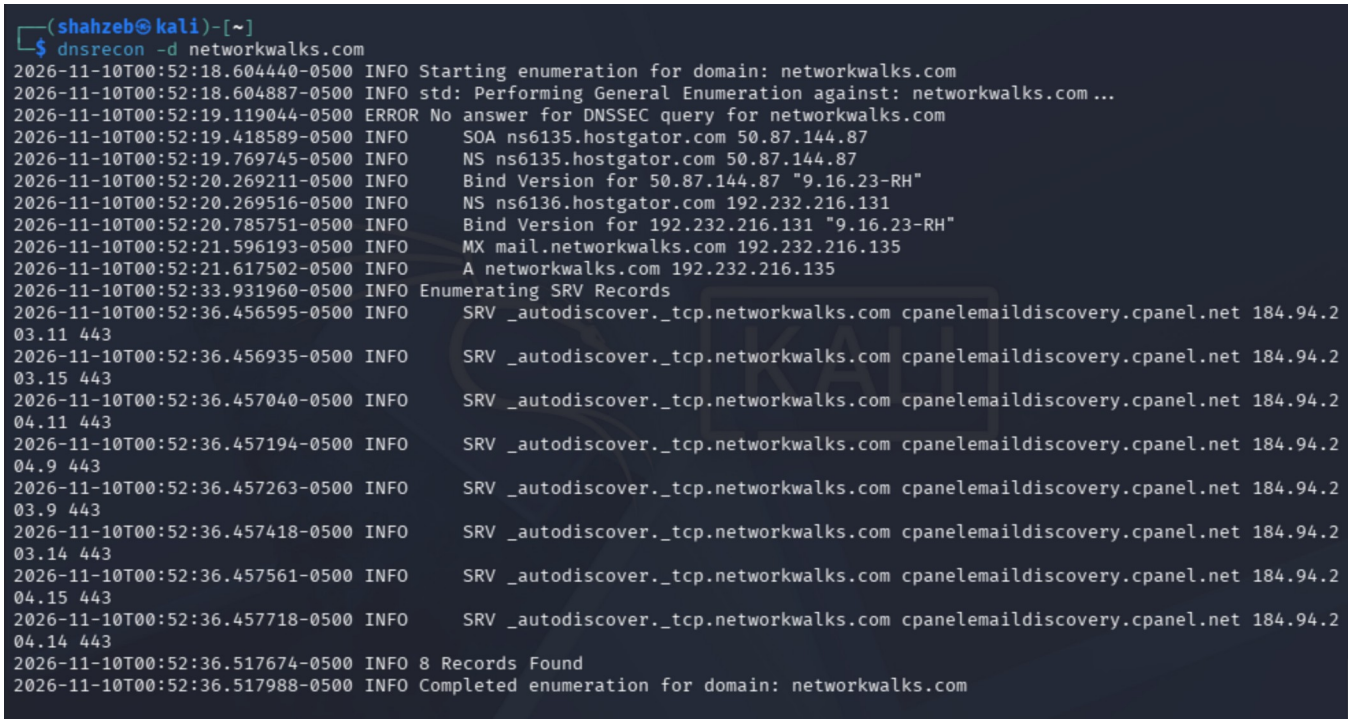
HTTP/2 response, Apache and cache headers, REST API links and redacted cookie. Supports F07, F08 and F09.

E05 WAFW00F detection



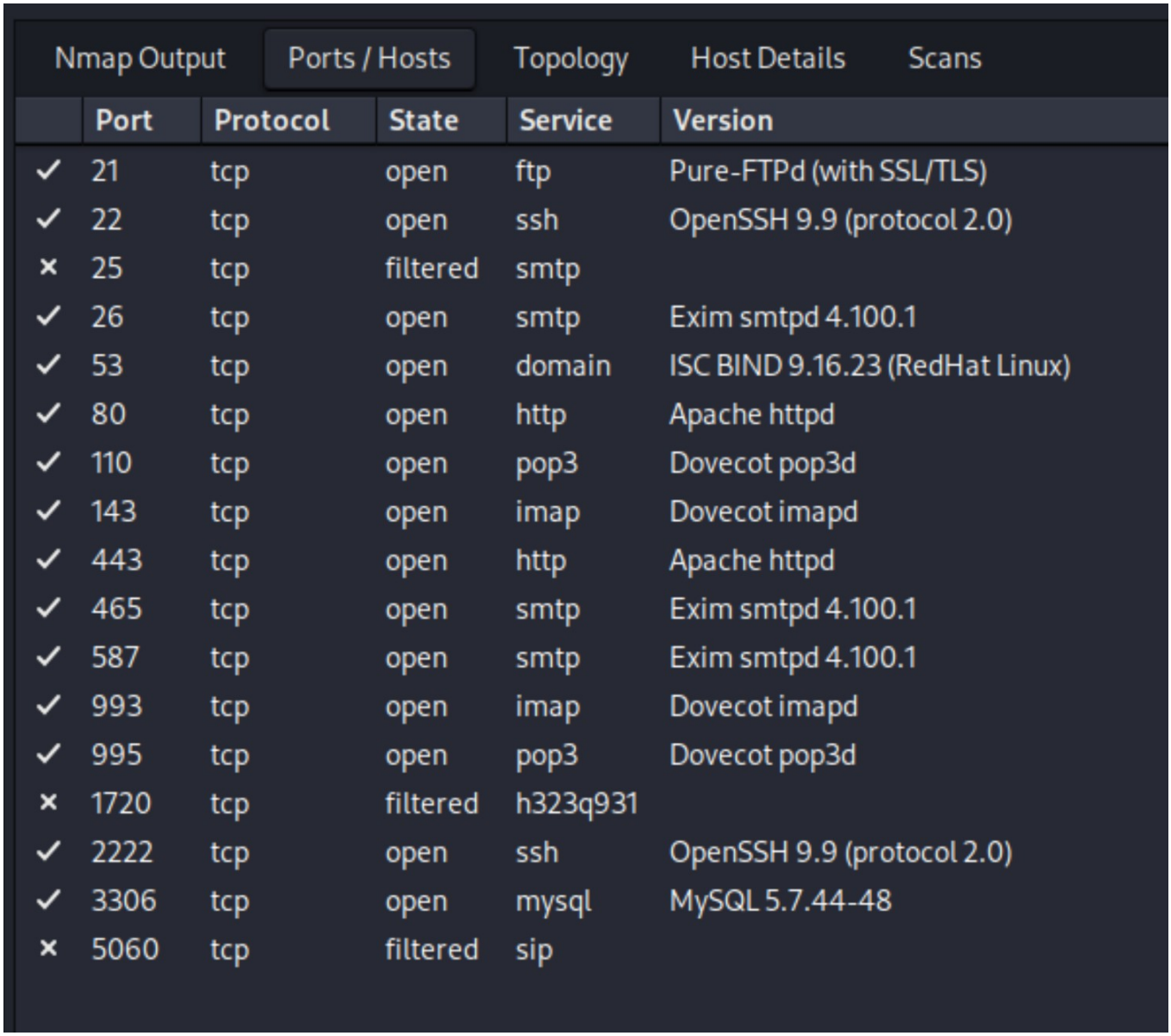
ModSecurity SpiderLabs identification in two requests. Records the observed defensive control F10.

E06 DNSRecon infrastructure enumeration



SOA, NS, MX, A and autodiscover SRV results, DNS version strings and a DNSSEC query without an answer. Supports F05, F06 and F09.

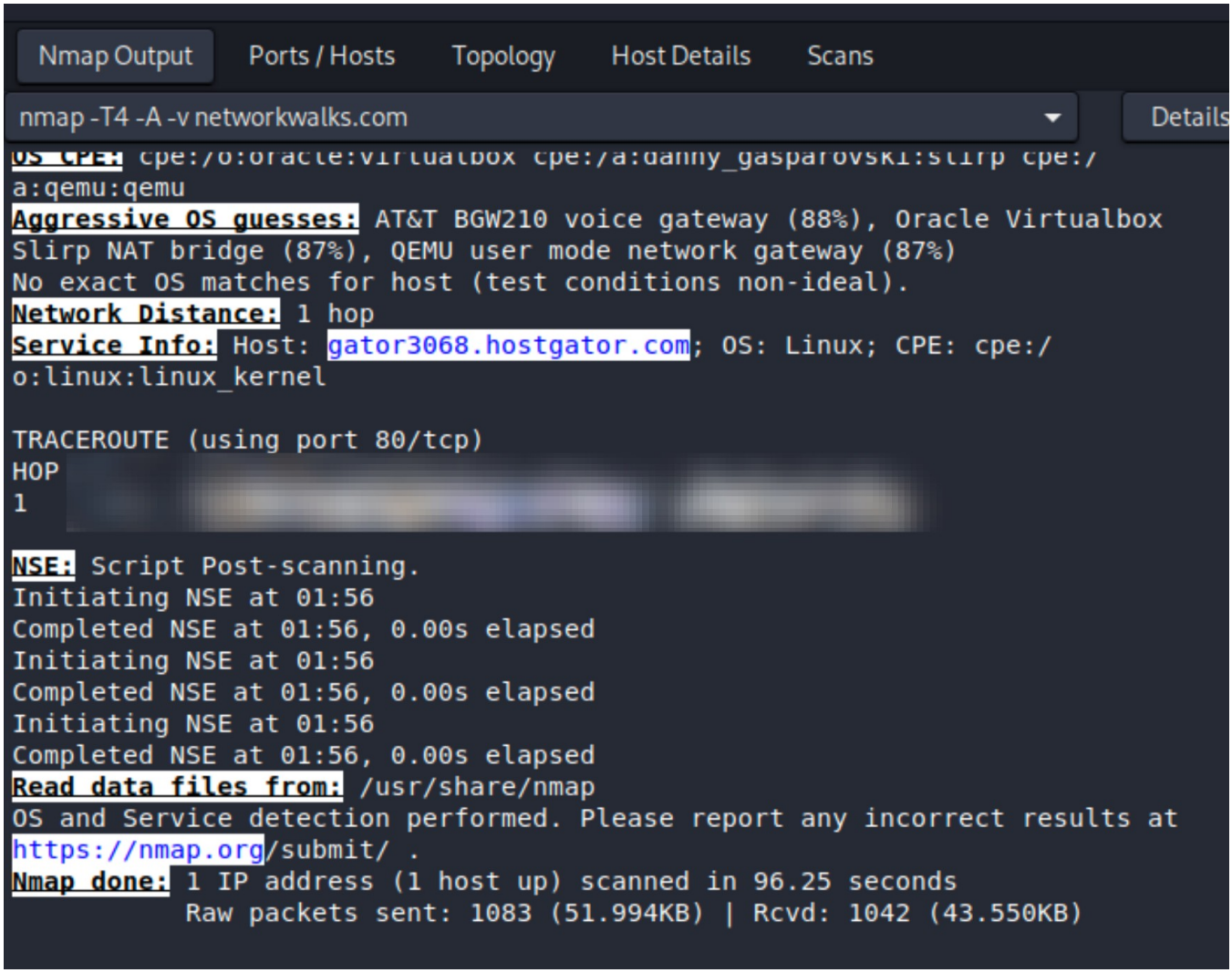
E07 Zenmap ports and service inventory



	Port	Protocol	State	Service	Version
✓	21	tcp	open	ftp	Pure-FTPd (with SSL/TLS)
✓	22	tcp	open	ssh	OpenSSH 9.9 (protocol 2.0)
×	25	tcp	filtered	smtp	
✓	26	tcp	open	smtp	Exim smtpd 4.100.1
✓	53	tcp	open	domain	ISC BIND 9.16.23 (RedHat Linux)
✓	80	tcp	open	http	Apache httpd
✓	110	tcp	open	pop3	Dovecot pop3d
✓	143	tcp	open	imap	Dovecot imapd
✓	443	tcp	open	http	Apache httpd
✓	465	tcp	open	smtp	Exim smtpd 4.100.1
✓	587	tcp	open	smtp	Exim smtpd 4.100.1
✓	993	tcp	open	imap	Dovecot imapd
✓	995	tcp	open	pop3	Dovecot pop3d
×	1720	tcp	filtered	h323q931	
✓	2222	tcp	open	ssh	OpenSSH 9.9 (protocol 2.0)
✓	3306	tcp	open	mysql	MySQL 5.7.44-48
×	5060	tcp	filtered	sip	

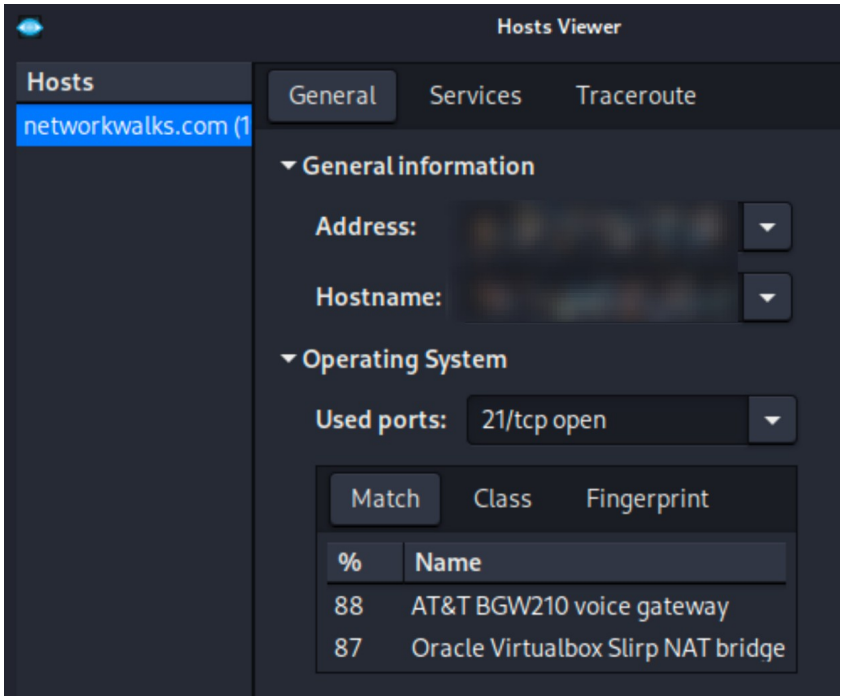
Fourteen open TCP ports and three filtered entries, including SSH on 22 and 2222 and MySQL on 3306. Supports F01 to F05.

E08 Nmap output and completion



Recorded command, non-ideal OS matching, Linux service hint, one-hop route, scan duration and packet totals. Supports F11.

E09 Zenmap Host Viewer



Host details with redacted address and hostname, port 21 used for fingerprinting and imperfect OS match percentages. Supports F11.

E10 Zenmap topology



Localhost and connected-node visualization. Redaction and limited route evidence prevent physical-network conclusions. Supports F11.